LABORATUVAR 2 · PAKETPRO 3000 · Paketleme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad Beşir Can Barutçu | Grup | Tarih 23.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Gradius için 7 zone: Z0 Kurumsal IT (müşteri: ERP, MES, ofis) – kapsam dışı · Z1 DMZ: jump server, IoT/veri broker, patch ve yedek sunucusu (SL-T 2) · Z2 Supervisory: hat HMI, endüstriyel PC/reçeteler (SL-T 2) · Z3 Vision/AI: kameralar, vision PC, tutma noktası modeli (SL-T 2) · Z4 Kontrol: hat PLC'si, robot kontrolcüsü, servo sürücüler, konveyör VFD'leri, checkweigher (SL-T 2) · Z5 Safety: Safety PLC, E-stop, kapı kilitleri, ışık perdeleri, robot safety, STO (SL-T 3) · Z6 Harici: KANTEC uzak servis, IoT cloud (güvenilmez). Zone'a girmeyenler: USB portları ve servis laptop'u fiziksel conduit (C8); paylaşılan servis hesabı varlık değil zafiyettir, silinir.

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Gradius'ta karşılığı KANTEC'in uzak servis erişimi. Varsayım: bugün internetten doğrudan IPC/PLC ağına bağlanıyor, yani fiilen Z2/Z4 içinde. KALAMAZ: internetteki biri hat PLC'sine, oradan Safety PLC'ye ulaşabilir. Z1 DMZ'ye taşınmalı; sadece VPN + MFA + jump server ile, varsayılan kapalı, loglanarak erişilmeli ve Z5'e asla ulaşmamalı.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

C1 Z0↔Z1: firewall, varsayılan reddet, doğrudan IT-OT yolu yok · C6 Z6↔Z1: VPN, MFA, kişisel hesap, varsayılan kapalı, log · C7 Z1→Z6: IoT telemetri sadece dışarı, TLS + cihaz sertifikası · C2 Z1↔Z2: firewall, sertifika, oturum kaydı · C3 Z2↔Z4: rol tabanlı yazma, HMI/IPC'de mühendislik aracı yok · C4 Z3→Z4: tek yön koordinat, robot kontrolcüsünde makullük limiti · C5 Z5→Z4: sadece safety durum okuma, ağdan yazma yok, CRC izlenir · C8 USB/laptop: kapalı/kilitli, sadece yönetilen laptop.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: makineye doğrudan bağlantı yok, tek kontrollü giriş (Z1).
Tünel?	Açık / VPN	VPN: trafik şifreli, IPC/PLC internete açık değil.
Kimlik?	Parola / MFA	MFA: çalınan KANTEC mühendis parolası tek başına yetmez.
Hesap?	Paylaşılan / Kişisel	Kişisel: her işlem bir kişiye bağlı, ortak "servis" hesabı yok.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: CRA 24s/72s/14 gün için kanıt.
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: müşteri her oturumu süreli açar.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.